

Section 1: Executive Summary

The Grand-Marina Hotel relies on Hydroficient's Hydrlogic devices to monitor, control, and protect its water infrastructure. Essentially, it tracks water consumption, upstream, downstream and the pressure at which the water flows. This is done, as you have required, to reduce cost and to control contingencies. These hydrologic devices constantly measure these variables and send this information to a cloud, and then to a dashboard where we can control operations and also view certain information (based on authority).

This threat Model outlines possible risks and failures that could either cause dangerous accidents like water outages or overflow, or overuse of resources, which could incur serious costs. The whole system is based on IoT devices that are usually out of date, have low technical complexity or are hard to change or update, making it a very easy target in the long run.

My major concerns are that:

- *Loss of availability or integrity of the Remote control can cause an inability to stop leaks or prevent flooding, leading to high-impact casualties.*
- *Attacks on the Cloud API can cause system-wide control or disruption*
- *Tampering with hydrologic device data or commands can lead to delayed decisions, especially when something goes wrong.*

Section 2: System Overview

- *The hotel consists of 500 rooms (**Hydroficient customer**)*
- *3 HYDROLOGIC flow management devices (**one per water service line**)*
- *Cloud-based monitoring and control*
- *Web dashboard for operators and management*
- *Remote shutoff and gate control capability*

Please click on the link below

XML

[Diagram](#)

How it works:

1. The Hotel gets its water from its water source at a certain pressure.
2. Hydrologic devices collect information like water pressure and upstream speed
3. This information is carried to a central cloud through a broker.
4. Data and information are translated in the cloud
5. This information appears (in real-time) on a dashboard, where instructions and commands can also be made based on any situation to control variables.

Section 3: Asset Inventory

Asset	Description	C Priority	I Priority	A Priority
HYDROLOGIC Devices	3 flow management units	High	Critical	Critical
Web Dashboard	Operator monitoring interface	High	High	Critical
Cloud API	Device-to-cloud communication	High	Critical	Critical
Remote Controls	Gate adjustments, emergency shutoff	High	Critical	Critical
Consumption Data	Savings reports, billing records	Critical	Critical	High
Remote Shutoff	Contingencies, moderating and notifications	Critical	Critical	Critical

Reasoning:

1. **Integrity is Critical** in devices or parts of the system where accurate data is needed. They directly affect water distribution and operation decisions. We need critical integrity in these places because the nature of the data sent or received affects all decision-making processes. That's why for systems like Hydrologic devices, Cloud APIs, and remote controls, integrity failures can cause immediate safety and financial risks.
2. **Confidentiality is Critical** where the data collected is really sensitive. That's why consumption data must be kept confidential because the information in it can give hackers a way through the whole system. However, in other places like API's and the dashboard, confidentiality doesn't matter as much, but it is still not negligible.
3. **Availability is Critical** for operational and emergency-related components. Downtime in the web dashboard, remote controls, or shutoff mechanisms could prevent staff from responding to leaks, overflows, or emergencies in real time. In a commercial hotel

environment, loss of availability could lead to property damage, regulatory violations, and guest safety concerns.

Section 4: STRIDE Analysis

Component 1: HYDROLOGIC Devices

Threat	Scenario	Likelihood	Impact	Risk
Spoofing	Hacker poses as a user on the dashboard and sends commands to the hydrologic device	Medium	Critical	High
Tampering	Attacker modifies device sensor data	Medium	Critical	High
Repudiation	An operator or attacker performs actions on the device without logging in the right way, making it impossible to trace the wrongdoer.	Medium	High	Medium
Info Disclosure	Somebody somehow gets access to the hotel's WiFi, captures unencrypted data transmissions, and learns the configuration of hydrologic devices.	Medium	High	Medium
Denial of Service	Somebody disrupts the signals from the devices and prevents the transmission of data	Medium	Critical	Critical
Elevation of Privilege	Attacker gains higher-level access to the device, allowing full control of operations	Medium	High	High

Component 2: Web Dashboard

Threat	Scenario	Likelihood	Impact	Risk
Spoofing	Attacker uses stolen operator credentials (from a phishing email) to	Medium	High	Critical

	access the dashboard from outside the hotel			
Tampering	The attacker may change the parameters for some alerts. Maybe changing the alert of pressure from 42 psi to maybe 100psi	Medium	High	High
Repudiation	Someone claims they didn't see the alert yet, the alert went off.	Medium	Medium	Medium
Info Disclosure	Someone gets into the dashboard and exposes login details. One person's details are more than enough to cause a lot of damage.	Medium	High	High
Denial of Service	Attacker floods the dashboard with requests during a time when people with access to the dashboard are not paying attention to it.	Medium	High	High
Elevation of Privilege	A normal support staff gains administrative capabilities and has access to the whole network's resources and operational decisions	Medium	High	High

Component 3: Cloud API

Threat	Scenario	Likelihood	Impact	Risk
Spoofing	Somebody poses as a subscriber, and the cloud sends all information to the attacker's servers instead.	medium	High	Critical
Tampering	Somebody can gain access to the cloud database and mess with the data history.	Medium	High	High

Repudiation	The API actions are not properly logged, making it hard to trace someone who does a wrong command	Medium	High	Medium
Info Disclosure	After tampering with the database data and releasing it to other people, giving other attackers valuable information.	Medium	Critical	Critical
Denial of Service	API is overwhelmed or intentionally taken offline, stopping device communication. Data is received from hydrologic devices, but not interpreted or sent to any subscriber.	Medium	Critical	Critical
Elevation of Privilege	A Grand Marina support employee accesses administration privileges and data without authorisation	Medium	Critical	Medium

Component 4: Remote Controls (Gate/Shutoff)

Threat	Scenario	Likelihood	Impact	Risk
Spoofing	The attacker sends fake critical alerts for a wateroverflow, causing unnecessary anxiety	Medium	Critical	High
Tampering	Attacker get's into the systems and disguises an actual alert reading (Anomaly) as a normal reading and allows the gate to stay open when it is meant to be closed.	Low	Critical	Critical
Repudiation	Too many people have access to the remote shutoff system,	Medium	High	Medium

	making it hard to pinpoint the person who mistakenly shutoff a gate.			
Info Disclosure	Someone exposes the control logic or command structure	Low	High	Medium
Denial of Service	The shutoff devices stop working as a result of someone overflowing the system with commands.	Medium	Critical	Critical
Elevation of Privilege	The attacker gains full control of the remote control functions	Low	Critical	High

Section 5: Risk Summary

Critical Risks

- Loss of availability or integrity of the Remote control:**
 Attacks such as **DoS, Spoofing, or Tampering** against remote controls and shutoff systems are critical because they directly affect physical water flow and response in case of an emergency. If these systems become unavailable or are manipulated, the hotel may be unable to stop leaks or prevent flooding, leading to high-impact casualties.
- Attacks on the Cloud API enable system-wide control or disruption:**
 The **Cloud API** is the centralised control point for communication between the hydrologic devices, the dashboards, and the subscribers. So, a successful attack involving **Spoofing, Information disclosure, or DoS** could impact multiple hydrologic devices all at the same time. And because of its broad reach and dependency on other components, any attack at the API level has system-wide consequences, making this a critical risk.
- Tampering with hydrologic device data or commands:** Modification of sensor readings, firmware, or control commands on hydrologic devices poses a critical risk because it can cause incorrect water flow decisions. It just makes it harder to trust the system operations. This can lead to delayed decisions when something goes wrong.

High Risks

- **Unauthorised access to the Web Dashboard through stolen credentials or Elevation of Privilege: Elevation-of-privilege** attacks against the Web Dashboard are high risk because they allow attackers to manipulate alerts, thresholds, and operational variables. These actions can mislead operators and result in poor decision-making that affects device behaviour and the safety of the whole system.
- **DoS attacks targeting Web dashboards:**
DoS attacks across multiple components are high risk due to their ability to disrupt monitoring, communication, and response capabilities. Even temporary loss of visibility or control can significantly impact operations.
- **Information disclosure of operation or configuration data:**
Information disclosure across the dashboard, API, or devices can provide attackers with valuable knowledge about the system, allowing other malicious attackers to have a go at the hotel. This could also lead to future attacks

Medium Risks

- Insufficient login tracking and accountability leading to **Repudiation**
- **Elevation of privilege** or internal misuse

Section 6: Recommended Mitigations

Critical Risks:

Risk	Proposed Mitigation	Implementation Complexity
Loss of availability or integrity of the Remote control	Implement strong authentication and authorisation for all remote control actions	Medium – requires configuration changes and device support
Attacks on the Cloud API enable system-wide control or disruption	Use rate limiting and black hole rerouting (I did not use AI, I promise)	Medium – involves API configuration, access tokens and certificates, and monitoring

Tampering with hydrologic device data or commands	Implement data validation and anomaly detection for sensor readings	High – requires device-level security controls and firmware updates
--	---	---

High Risks:

Risk	Proposed Mitigation	Implementation Complexity
Unauthorised access to the Web Dashboard through stolen credentials or Elevation of Privilege	Enable multi-factor authentication for all dashboard users	Medium – requires configuration changes
DoS attacks targeting Web dashboards	Use rate limiting and black hole rerouting.	Medium – depends on hosting and how the network is set up
Information disclosure of operation or configuration data	Restrict access to configuration data based on user roles	Medium – mainly configuration changes.

Medium Risks:

Risk	Proposed Mitigation	Implementation Complexity
Insufficient login tracking and accountability leading to Repudiation	Ensure each login includes timestamps, user IDs, and the action taken	Medium – Login configurations

Elevation of privilege or internal misuse	Separate administrative and normal roles	Medium – policy enforcement and monitoring setup
--	--	--